Universidad Mariano Gálvez de Guatemala
Facultad de Ingeniería en Sistemas de Información
Maestría en Seguridad Informática

PRACTICA APLIACIONES WEB CON OWASP

TAREA INDIVIDUAL

Instrucciones:

Utilizar la máquina virtual bWAPP y explotar como mínimo 10 vulnerabilidades de forma exitosa, donde muestre el uso de la máquina virtual y como mitigar esas vulnerabilidades, detallarlo con pantallazos de cada prueba, en un documento con caratula trabajarlo de manera individual y subirlo a la plataforma CANVAS.

Pasos que seguir:

1. Instalar la máquina Virtual de Oracle (adjunta)

2. Descargar la maquina virtual bWAPP

link : https://sourceforge.net/projects/bwapp/files/bee-box/bee-box_v1.6.7z/download

3. Descomprimir los archivos de bee-box_v1.6

4. Correr la máquina virtual box y agregar la maquina con el nombre (bee-box.vmdk)

5. Se debe mostrar algo como esto:

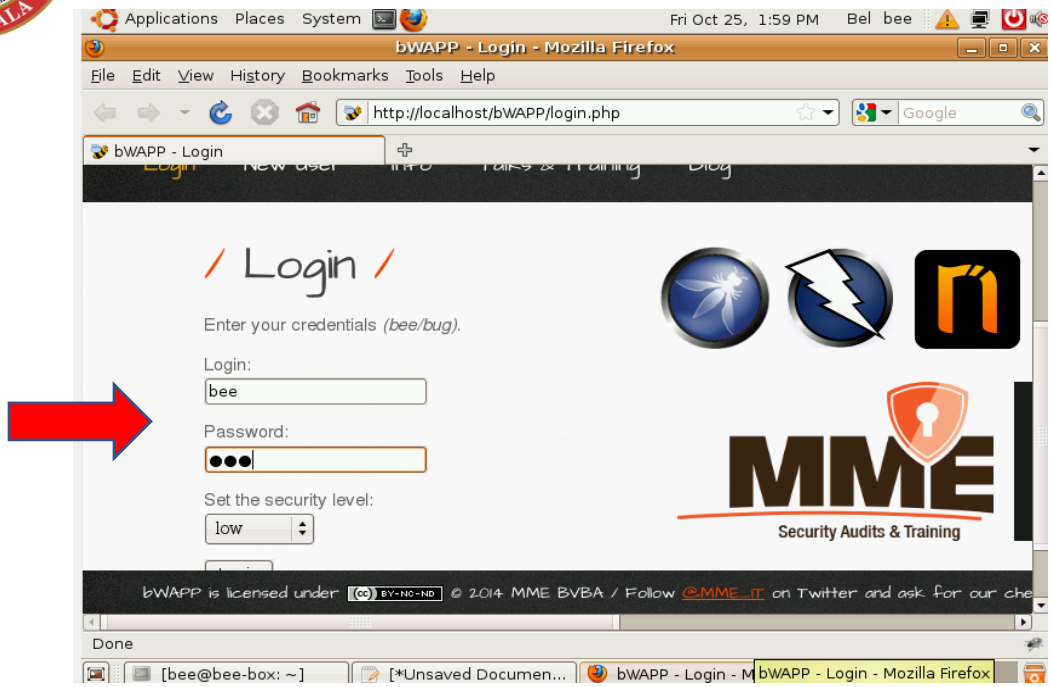


6. Ingresar al Explorador Mozilla FireFox

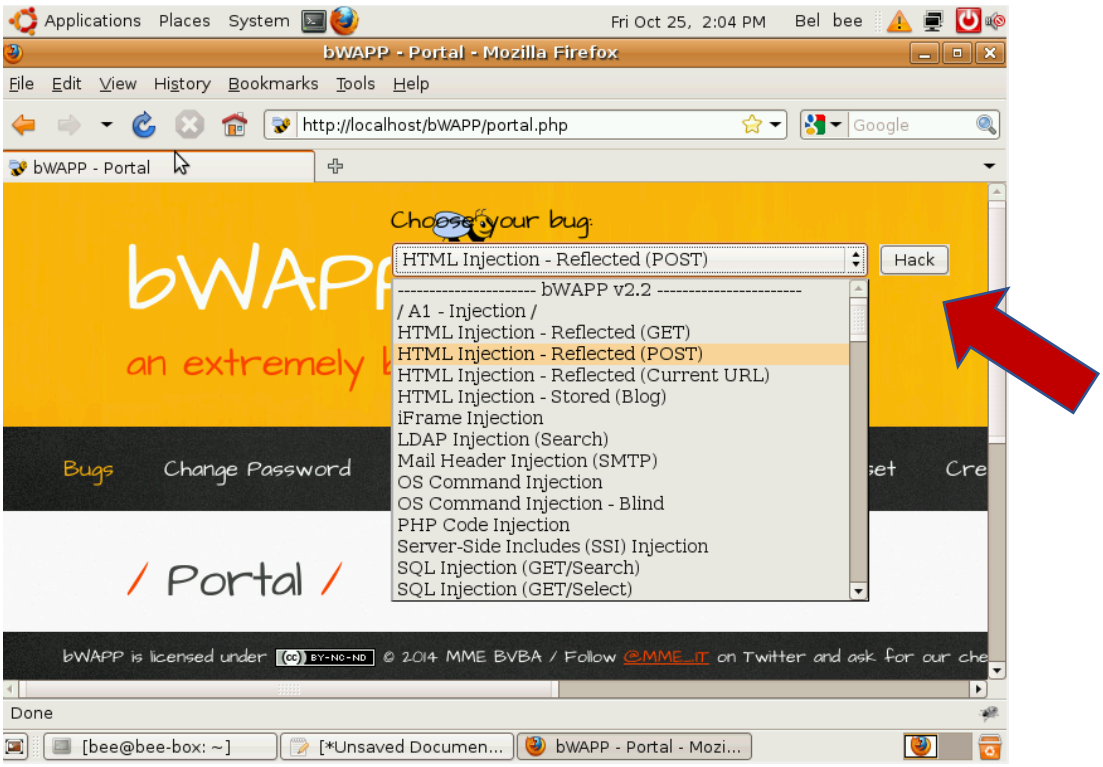


7. Ingresar usuario y contraseña

Usuario: **bee**
Password: **bug**

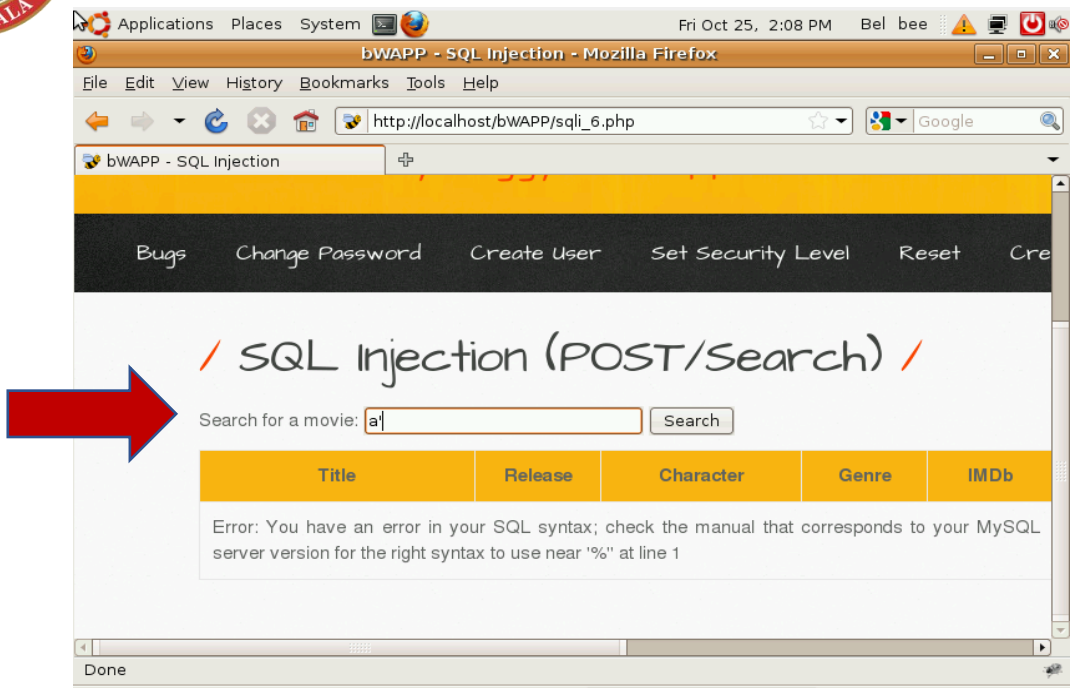


8. Muestra el listado de vulnerabilidad de las páginas web tomando como base OWASP



9. ejemplo de SQL Injection

Universidad Mariano Gálvez de Guatemala
Facultad de Ingeniería en Sistemas de Información
Maestría en Seguridad Informática



Responder con el siguiente formato:

Amenaza OWASP: HTML Injection – Reflected (Post)

Descripción de la Amenaza:
La aplicación recibe información enviada por el usuario y la devuelve en la respuesta HTML sin validarla ni codificarla correctamente.

Nivel de Riesgo: Alto

Mitigación:

Implementación de expresiones regulares en los campos de texto para que no ingresen caracteres especiales, asimismo Los parámetros enviados por el usuario ya no son interpretados como contenido HTML por el navegador, mitigando el riesgo de HTML Injection Reflected identificado por OWASP ZAP.